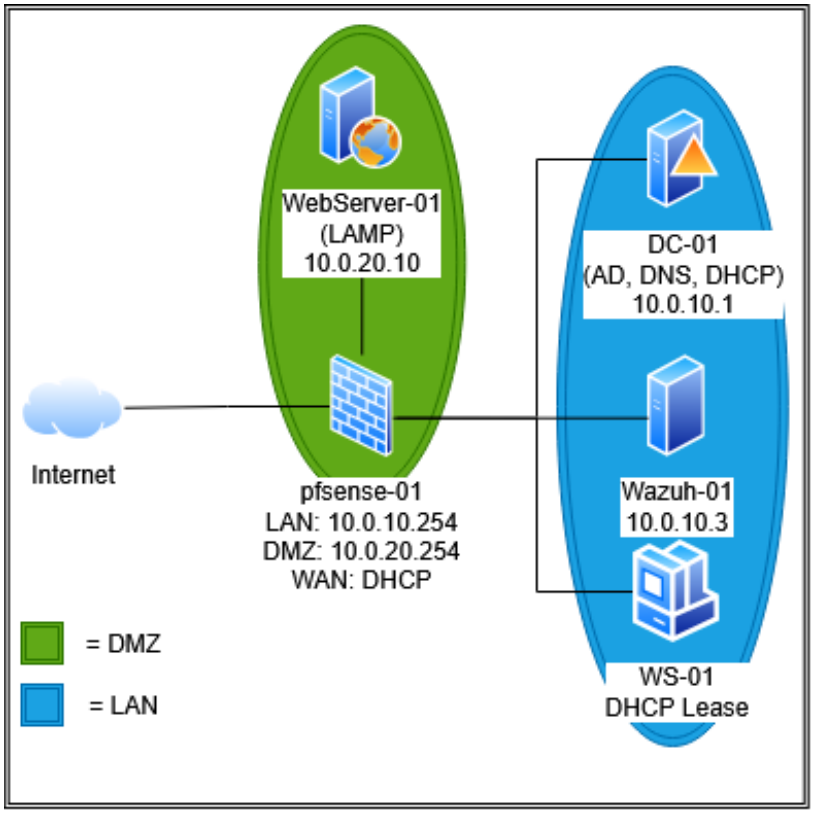
Segmented Security Home Lab: pfSense, Active Directory, Hardened LAMP, and Wazuh SIEM

A single-host virtual lab (Hyper-V) that simulates a small business network: a firewall with an isolated DMZ, a Windows domain, a hardened Linux web server, and a SIEM that detects attacks against it. Built to practice defensive security, infrastructure, and incident detection end to end.



Network diagram

What this project demonstrates

Area	What was done
Network segmentation	pfSense with three interfaces (WAN, LAN, DMZ), DMZ isolated from LAN by firewall rule
Identity	Windows Server domain `lab.internal` with AD DS, DNS, DHCP, and a domain-joined Windows 10 workstation
Linux hardening	Key-only SSH, ufw default-deny, fail2ban, Apache hardening, auditd, Lynis score 74 to 79
Application security	Least-privilege database user, secure vs. deliberately vulnerable PHP app (SQL injection)
Detection	Wazuh SIEM with agents on Windows and Linux; alerts for SQL injection, XSS, and web attack patterns

Environment

VM	OS	Zone	IP	Role
pfSense-01	pfSense 2.9.0 (development build)	Edge	WAN: DHCP, LAN: 10.0.10.254, DMZ: 10.0.20.254	Firewall, router, NAT
DC-01	Windows Server 2025 Standard (evaluation)	LAN	10.0.10.1	AD DS, DNS, DHCP
WS-01	Windows 10 Pro	LAN	DHCP (10.0.10.11)	Domain-joined client
Wazuh-01 (hostname Wazuh-Server)	Ubuntu 26.04 LTS	LAN	10.0.10.3	Wazuh 4.14.9 all-in-one
Webserver-01	Ubuntu 26.04 LTS	DMZ	10.0.20.10	Apache, PHP 8.5, MariaDB

- **Hypervisor:** Hyper-V on a 16-core / 32 GB host
- **Virtual switches:** Default Switch (WAN/NAT), one Private switch for LAN, one Private switch for DMZ
- **Domain:** `lab.internal` (NetBIOS LAB)

Contents

1. Network and firewall
2. Active Directory and Windows
3. Web server hardening
4. Application security: vulnerable vs. secure
5. Monitoring and detection with Wazuh
6. Troubleshooting and lessons learned
7. Limitations and future work

Sanitized configuration files are in `configs/`.

Key results

- **DMZ isolation proven:** from the web server, internet access and the Wazuh agent port work; ping and SMB to the domain controller are blocked and logged.
- **Hardening:** password SSH login refused (`Permission denied (publickey)`), Lynis hardening index 74 to 79 (audit tooling and stricter SSH settings), version banners removed, directory listing disabled, five security headers added.
- **Least privilege:** the app's database user cannot `DROP` tables (error 1142).
- **Detection:** Wazuh flagged SQL injection attempts (rule 31164), an XSS attempt (31105), and web attacks returning HTTP 200 (31106).

Skills practiced

pfSense firewall rules and NAT, Hyper-V networking, Active Directory (OUs, users, groups), DNS, DHCP, Ubuntu administration, SSH key authentication, ufw, fail2ban, Apache and PHP hardening, MariaDB privileges, Lynis auditing, Wazuh deployment and agent management, log analysis, SQL injection fundamentals, technical documentation.

1. Network and firewall

Topology

```
Internet --- [Default Switch/NAT] --- pfSense-01 ---+--- LAN 10.0.10.0/24 (Private switch)
                                      WAN: DHCP     |     DC-01, WS-01, Wazuh-01
                                                    |
                                                    +--- DMZ 10.0.20.0/24 (Private switch)
                                                          Webserver-01
```

A separate router VM was dropped from the original design. pfSense routes between the segments, which saved a VM on a RAM-limited host.

Design decisions

- **One virtual switch per segment instead of VLANs.** Private switches give real isolation (the only path between LAN and DMZ is through pfSense) with less configuration. VLAN trunking is a possible extension.
- **DMZ for the web server.** A public-facing server should not sit beside the domain controller.
- **pfSense WAN:** "Block private networks" is unchecked because the Hyper-V Default Switch uses a private subnet.

Interfaces

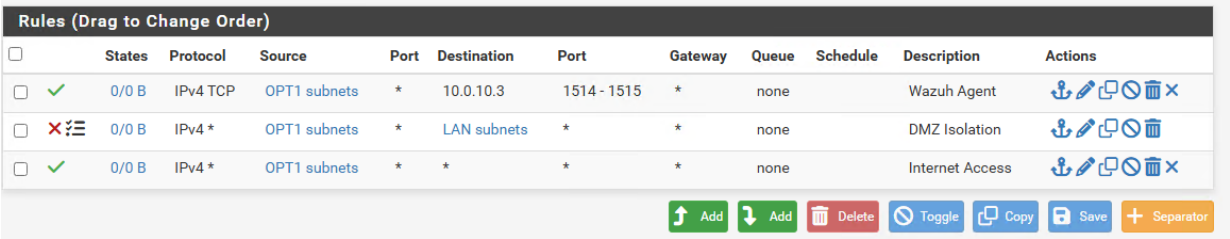
Interface	NIC	Address
WAN	hn0	DHCP from Default Switch
LAN	hn1	10.0.10.254/24
OPT1 (DMZ)	hn2	10.0.20.254/24

LAN rules

Default "Allow LAN to any" kept. pfSense is stateful, so replies to connections started from the LAN (SSH, browsing the web server, Wazuh enrollment) are allowed automatically.

DMZ rules (order matters, first match wins)

#	Action	Protocol	Source	Destination	Port	Purpose
1	Pass	TCP	DMZ subnets	10.0.10.3	1514-1515	Wazuh agent to manager
2	Block (logged)	Any	DMZ subnets	LAN subnets	any	DMZ isolation
3	Pass	Any	DMZ subnets	Any	any	Internet and updates

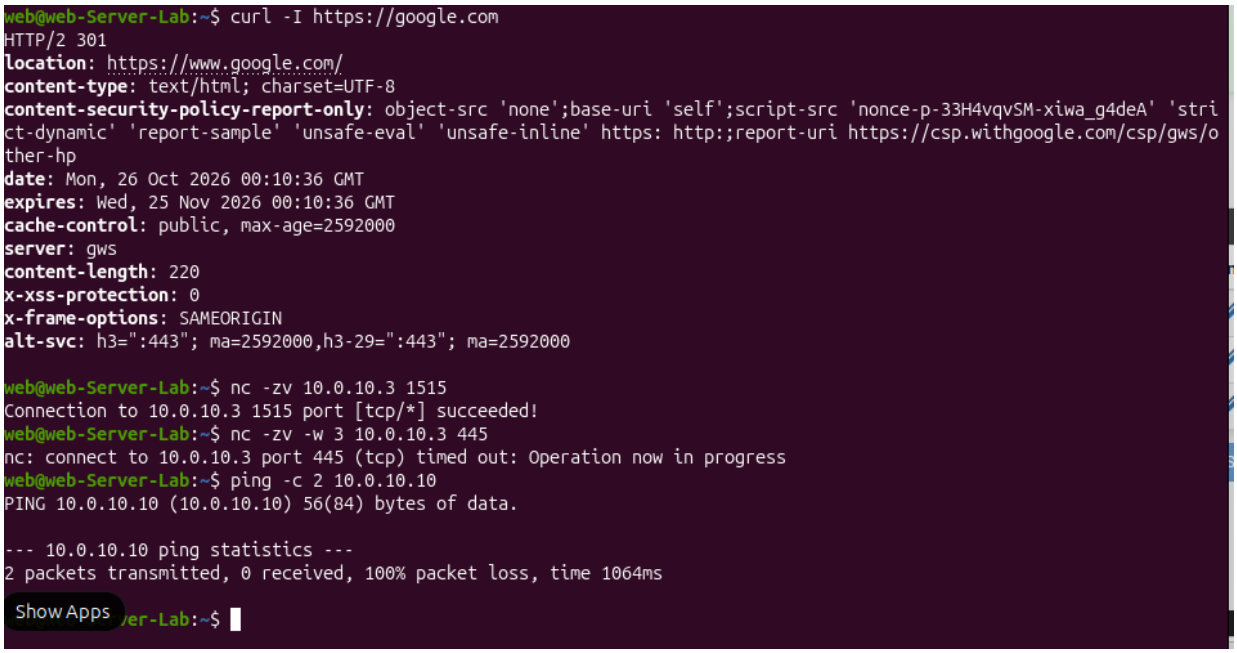


DMZ rules

Verification

Run from the web server:

```
curl -I https://google.com        # HTTP/2 301, internet works
nc -zv 10.0.10.3 1515             # succeeded, Wazuh rule works
nc -zv -w 3 10.0.10.3 445         # timed out, exception limited to 1514-1515
ping -c 2 10.0.10.10              # 100% loss, DMZ to LAN blocked
```



Allowed and blocked traffic

The pfSense firewall log confirms it. Each ping from the web server (10.0.20.10) to DC-01 (10.0.10.1) is dropped by the **DMZ Isolation** rule on OPT1, which is stronger evidence than the failed ping alone, since Windows Firewall also drops ICMP by default. The other rows are unrelated multicast noise from the DMZ interface (169.254.0.98), blocked by pfSense's default link-local rule.



pfSense log: DMZ Isolation blocking DMZ to LAN

Gotchas hit during the build

- A new OPT interface has no rules, so it drops everything until rules are added.
- The first draft of the rule list had the allow-any rule at the top, which would have made the block rule unreachable. Reordering fixed it.
- "OPT1 address" matches the firewall itself; "OPT1 subnets" matches the hosts behind it.

2. Active Directory and Windows

Services on DC-01

- Active Directory Domain Services, domain `lab.internal`
- DNS: DC-01 resolves the domain and forwards other queries to pfSense
- DHCP for the LAN: scope 10.0.10.0/24 with an address pool of 10.0.10.11 to 10.0.10.250. Infrastructure hosts sit outside the pool on static addresses (DC-01 10.0.10.1, Wazuh 10.0.10.3, pfSense 10.0.10.254), so a lease can never collide with them.
- Organizational units: a `LabEmployees` OU with two child OUs, `IT` and `Executive`. The IT OU holds a standard user account; the Executive OU holds a test account.
- Groups: the IT user is a member of `Domain Users`, a custom `HighLevelIT` security group, and the built-in `Remote Desktop Users` group, which allows remote access to domain-joined machines.

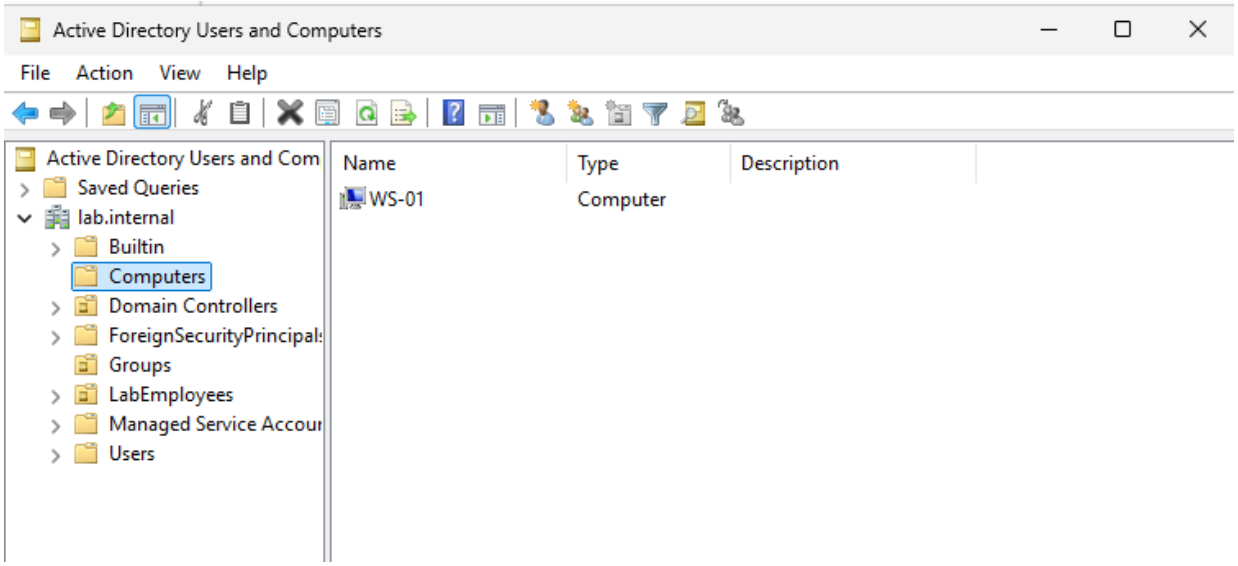
Client

WS-01 (Windows 10 Pro) is domain-joined and gets its address and DNS from DC-01 by DHCP (currently 10.0.10.11, the first address in the pool).

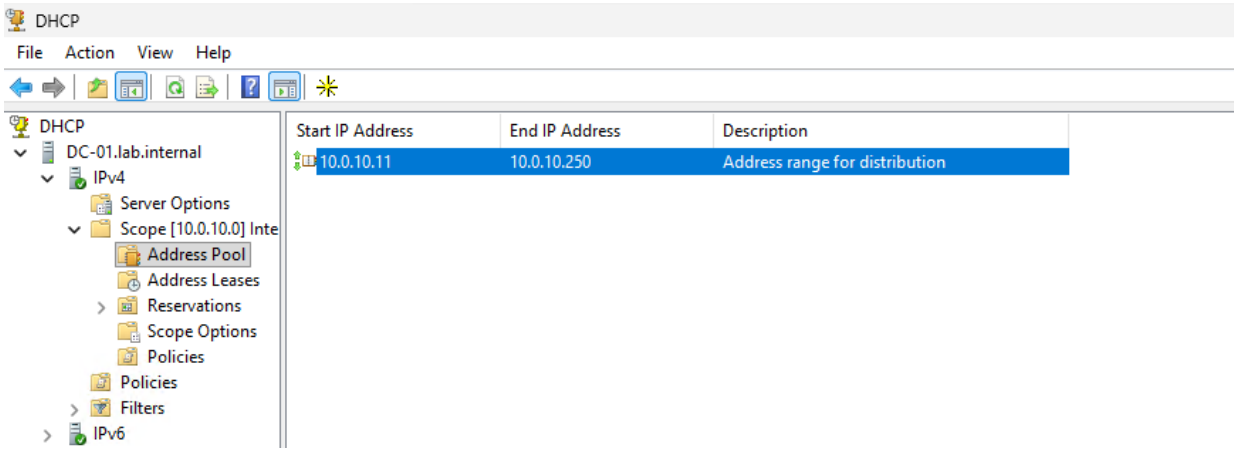
Naming

`lab.internal` was chosen because `.internal` is reserved for private use. It avoids the mDNS conflicts that `.local` can cause with Linux clients and avoids colliding with a real public domain.

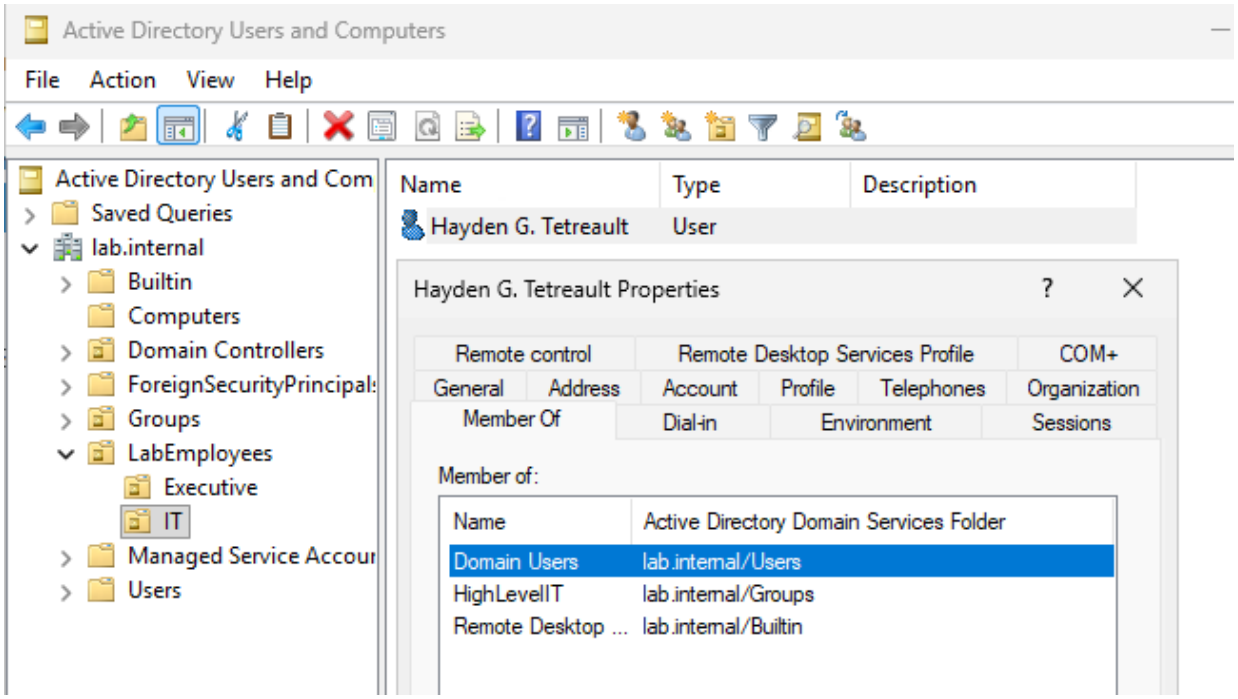
Evidence to add



WS-01 joined to lab.internal



DHCP address pool



IT OU user and group membership

Not implemented

No Group Policy objects were configured, including baseline policies for browsers or Windows hardening. Access rules in this lab rely on group membership only.

A second domain controller for redundancy and recovery practice was planned and not built. See Limitations.

3. Web server hardening (Webserver-01)

Ubuntu Server in the DMZ at 10.0.20.10, running Apache, PHP 8.5, and MariaDB (Ubuntu 26.04 LTS).

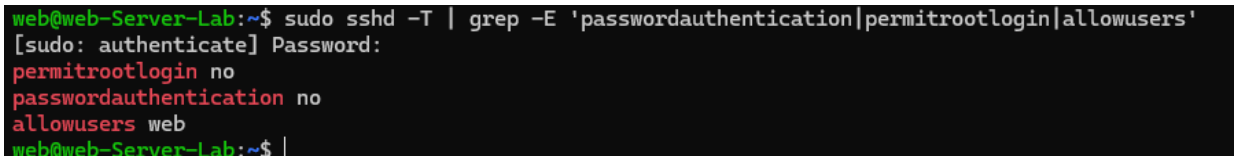
SSH

- OpenSSH server installed and restricted to the LAN by ufw
- Ed25519 key with passphrase, from the DC-01 management host
- Password authentication disabled, root login disabled, `AllowUsers web`

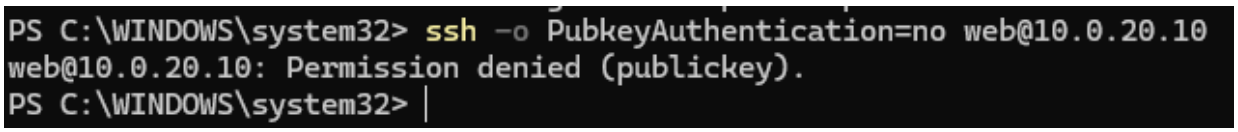
Config: `configs/sshd-01-hardening.conf`

Proof:

```
ssh -o PubkeyAuthentication=no web@10.0.20.10
web@10.0.20.10: Permission denied (publickey).
```



Effective sshd settings

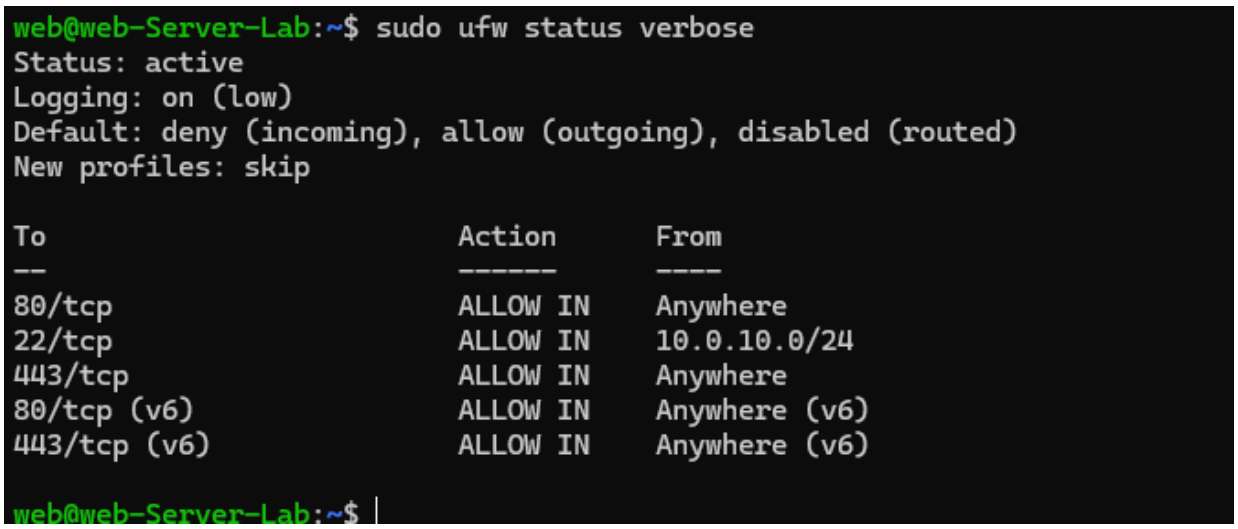


Password login refused

Firewall (ufw)

Default deny inbound, allow outbound. SSH only from 10.0.10.0/24; HTTP and HTTPS open.

Rules: `configs/ufw-rules.txt`



ufw status

fail2ban

sshd jail with `maxretry = 4`, `findtime = 10m`, `bantime = 1h`, reading from the systemd journal.

Config: `configs/fail2ban-jail.local`

```
web@web-Server-Lab:~$ sudo fail2ban-client status sshd
Status for the jail: sshd
|- Filter
|  |- Currently failed: 1
|  |- Total failed:     1
|  `- Journal matches:  _SYSTEMD_UNIT=ssh.service + _COMM=sshd
`- Actions
   |- Currently banned: 0
   |- Total banned:     0
   `- Banned IP list:
```

fail2ban status

Before the test the jail was active with one failure counted and no bans. After repeated failed logins from WS-01 (`ssh -o PubkeyAuthentication=no baduser@10.0.20.10`), the jail banned that address:

```
web@web-Server-Lab:~$ sudo fail2ban-client status sshd
Status for the jail: sshd
|- Filter
|  |- Currently failed: 0
|  |- Total failed:     4
|  `- Journal matches:  _SYSTEMD_UNIT=ssh.service + _COMM=sshd
`- Actions
   |- Currently banned: 1
   |- Total banned:     1
   `- Banned IP list:   10.0.10.11
web@web-Server-Lab:~$
```

fail2ban ban

Four failures were recorded and 10.0.10.11 was banned for one hour. Even with password login disabled, each rejected attempt still counts toward the ban.

Attack surface scan

`nmap -sV` from a LAN host shows only SSH and HTTP exposed, with everything else filtered.

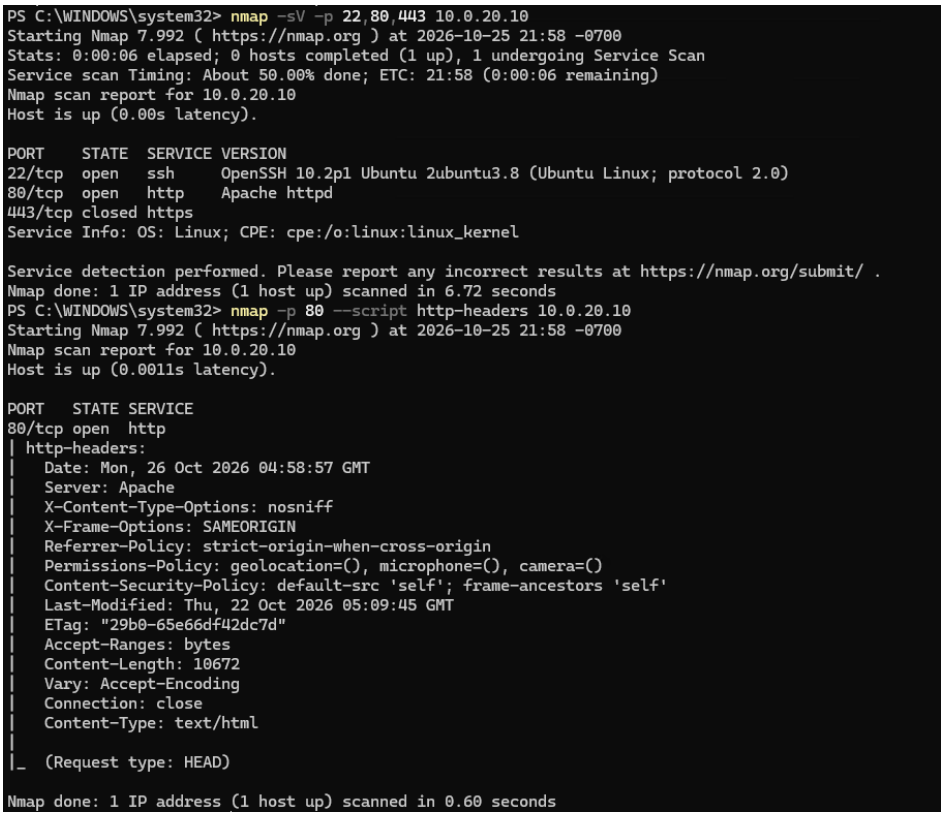
```
C:\Users\Administrator>nmap -sV 10.0.20.10
Starting Nmap 7.992 ( https://nmap.org ) at 2026-10-22 00:19 -0700
Nmap scan report for 10.0.20.10
Host is up (0.00089s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT    STATE  SERVICE VERSION
22/tcp  open   ssh     OpenSSH 10.2p1 Ubuntu 2ubuntu3.8 (Ubuntu Linux; protocol 2.0)
80/tcp  open   http    Apache httpd 2.4.66 ((Ubuntu))
443/tcp closed https
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.07 seconds

C:\Users\Administrator>
```

nmap scan

This scan was taken before the Apache hardening below and still reports the exact Apache version. After hardening, the same scan reports only `Apache httpd`, and a headers scan shows the security headers as an outside scanner sees them:



nmap after hardening

OpenSSH still discloses its version (`OpenSSH 10.2p1 Ubuntu`), which is not easily hidden; keeping the package patched is the mitigation (unattended-upgrades is enabled).

Apache hardening

Setting	Before	After
`Server` header	`Apache/2.4.66 (Ubuntu)`	`Apache`
404 page footer	Version and port disclosed	Removed
Directory listing	`/testdir/` listed `secret.txt`	403 Forbidden
Security headers	None	X-Content-Type-Options, X-Frame-Options, Referrer-Policy, Permissions-Policy, Content-Security-Policy

Config: `configs/apache-zz-hardening.conf`

The file is named `zz-` so it loads after Ubuntu's default `security.conf`, which sets `ServerTokens OS`; the last setting wins.

```
web@web-Server-Lab:~$ curl -I http://localhost/guestbook.php
curl -s http://localhost/does-not-exist | tail -3
sudo mkdir -p /var/www/html/testdir && sudo touch /var/www/html/testdir/secret.txt
curl -s http://localhost/testdir/
HTTP/1.1 200 OK
Date: Mon, 26 Oct 2026 00:25:44 GMT
Server: Apache/2.4.66 (Ubuntu)
Content-Type: text/html; charset=UTF-8

<hr>
<address>Apache/2.4.66 (Ubuntu) Server at localhost Port 80</address>
</body></html>
<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.01//EN" "http://www.w3.org/TR/html4/strict.dtd">
<html>
 <head>
  <title>Index of /testdir</title>
 </head>
 <body>
<h1>Index of /testdir</h1>
  <table>
   <tr><th valign="top"><img src="/icons/blank.gif" alt="[ICO]"></th><th><a href="?C=N;O=D">Name</a></th><th><a href="
?C=M;O=A">Last modified</a></th><th><a href="?C=S;O=A">Size</a></th><th><a href="?C=D;O=A">Description</a></th></tr>
   <tr><th colspan="5"><hr></th></tr>
<tr><td valign="top"><img src="/icons/back.gif" alt="[PARENTDIR]"></td><td><a href="/">Parent Directory</a></td><td>&n
bsp;</td><td align="right">  - </td><td> </td></tr>
<tr><td valign="top"><img src="/icons/text.gif" alt="[TXT]"></td><td><a href="secret.txt">secret.txt</a></td><td align
="right">2026-10-25 17:25  </td><td align="right">  0 </td><td> </td></tr>
   <tr><th colspan="5"><hr></th></tr>
</table>
<address>Apache/2.4.66 (Ubuntu) Server at localhost Port 80</address>
</body></html>
```

Apache before

```
web@web-Server-Lab:~$ curl -I http://localhost/guestbook.php
HTTP/1.1 200 OK
Date: Mon, 26 Oct 2026 00:37:37 GMT
Server: Apache
X-Content-Type-Options: nosniff
X-Frame-Options: SAMEORIGIN
Referrer-Policy: strict-origin-when-cross-origin
Permissions-Policy: geolocation=(), microphone=(), camera=()
Content-Security-Policy: default-src 'self'; frame-ancestors 'self'
Content-Type: text/html; charset=UTF-8

web@web-Server-Lab:~$ curl -s http://localhost/does-not-exist | tail -3
<h1>Not Found</h1>
<p>The requested URL was not found on this server.</p>
</body></html>
web@web-Server-Lab:~$ curl -s http://localhost/testdir/
<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.01//EN" "http://www.w3.org/TR/html4/strict.dtd">
<html><head>
<title>403 Forbidden</title>
</head><body>
<h1>Forbidden</h1>
<p>You don't have permission to access this resource.</p>
</body></html>
web@web-Server-Lab:~$
```

Apache after

System hardening and Lynis

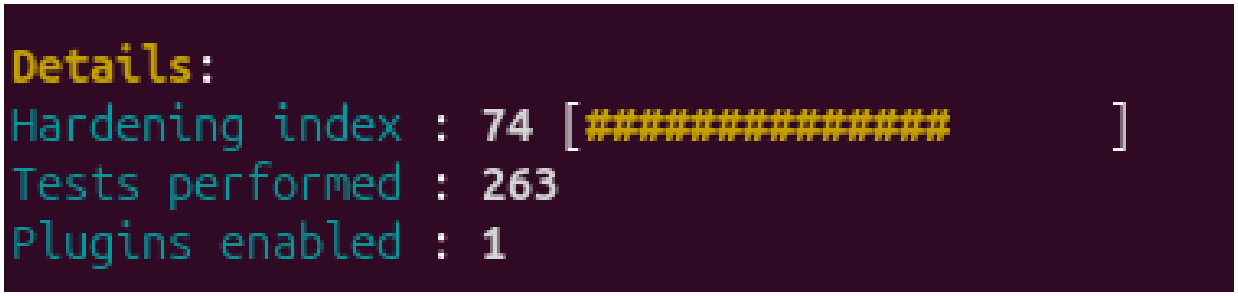
The 74 baseline was taken after the SSH, ufw, fail2ban, and Apache hardening above. Two further changes were then made:

1. Installed packages that Lynis checks for: `auditd` (audit logging), `unattended-upgrades` (automatic security patches), `debsums` (package file integrity), `acct` (process accounting), `sysstat`, `libpam-tmpdir`,

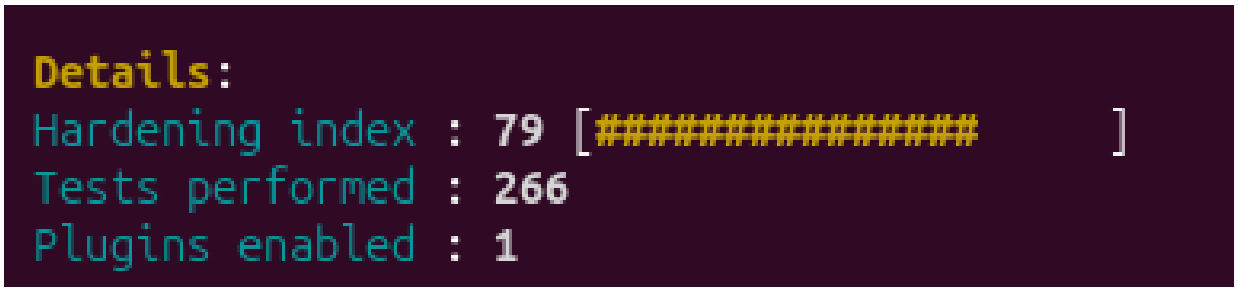
`apt-show-versions`, and `apt-listchanges`.

2. Added further SSH restrictions to the hardening file: `AllowTcpForwarding no`, `AllowAgentForwarding no`, `MaxSessions 2`, `TCPKeepAlive no`, and `LogLevel VERBOSE`.

	Before	After
Hardening index	74	79
Tests performed	263	266



Lynis before



Lynis after

Reading the score honestly: the 5-point gain came from the audit and patching tooling and the stricter SSH settings. The Apache hardening did not move the score, because Lynis awards little for web server settings. It is better shown by the before/after `curl` and nmap output above. Some remaining Lynis suggestions were deliberately skipped because they trade usability for small gains.

Not done

HTTPS with a self-signed certificate and HSTS were planned and not implemented.

4. Application security: vulnerable vs. secure

A small PHP guestbook backed by MariaDB, built in a secure version and a deliberately vulnerable copy to compare attacks, defenses, and detections. The vulnerable page was restricted to the LAN and was removed once testing finished, along with its demo tables.

Least-privilege database user

The app connects as `guestbook_app`, which has only `SELECT, INSERT, UPDATE, DELETE` on the `guestbook` database. Credentials live in `/etc/guestbook/config.php` (root:www-data, mode 640), outside the web root.

```
SELECT CURRENT_USER();      -> guestbook_app@localhost
DROP TABLE entries;         -> ERROR 1142: DROP command denied
```

```
MariaDB [guestbook]> SELECT CURRENT_USER();
+-------------------------+
| CURRENT_USER()          |
+-------------------------+
| guestbook_app@localhost |
+-------------------------+
1 row in set (0.000 sec)

MariaDB [guestbook]> SHOW GRANTS;
+-------------------------------------------------------------------------------------------------------------------------------
-+
| Grants for guestbook_app@localhost
 |
+-------------------------------------------------------------------------------------------------------------------------------
-+
| GRANT USAGE ON *.* TO `guestbook_app`@`localhost` IDENTIFIED BY PASSWORD
 |
| GRANT SELECT, INSERT, UPDATE, DELETE ON `guestbook`.* TO `guestbook_app`@`localhost`
 |
+-------------------------------------------------------------------------------------------------------------------------------
-+
2 rows in set (0.000 sec)
```

Grants

The privilege test, run against a throwaway table so the app's real data was never at risk:

```
MariaDB [guestbook]> SELECT CURRENT_USER();
+-------------------------+
| CURRENT_USER()          |
+-------------------------+
| guestbook_app@localhost |
+-------------------------+
1 row in set (0.000 sec)

MariaDB [guestbook]> DROP TABLE drop_test;
ERROR 1142 (42000): DROP command denied to user 'guestbook_app'@'localhost' for table `guestbook`.`drop_test`
MariaDB [guestbook]>
```

DROP denied

Lesson: the first `DROP TABLE` *test succeeded because it was run as root by mistake.* `SELECT CURRENT_USER();` *before testing privileges avoids that. The password hash in the screenshot is redacted.*

Setup script: `configs/guestbook-db-setup.sql`

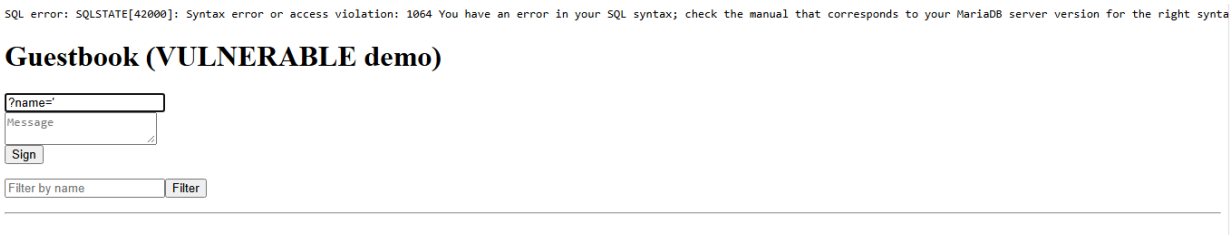
Secure vs. vulnerable code

	Secure (`guestbook.php`)	Vulnerable demo
SQL	`prepare('... WHERE name = ?')`	`"... WHERE name = '$filter'"`
Output	`htmlspecialchars()`	Raw output
Errors	Exceptions not displayed	Raw SQL error shown

Attacks run (from DC-01)

Test	Payload	Vulnerable page	Secure page
1. Error disclosure	`?name='`	Raw `SQLSTATE[42000]` MariaDB error	No error
2. Filter bypass	`?name=' OR '1'='1`	Returns entries regardless of filter	No rows
3. Data leak	`?name=' UNION SELECT username,secret,NOW() FROM staff_demo-- -`	Fake secrets displayed as entries	No rows

Vulnerable page



SQL error

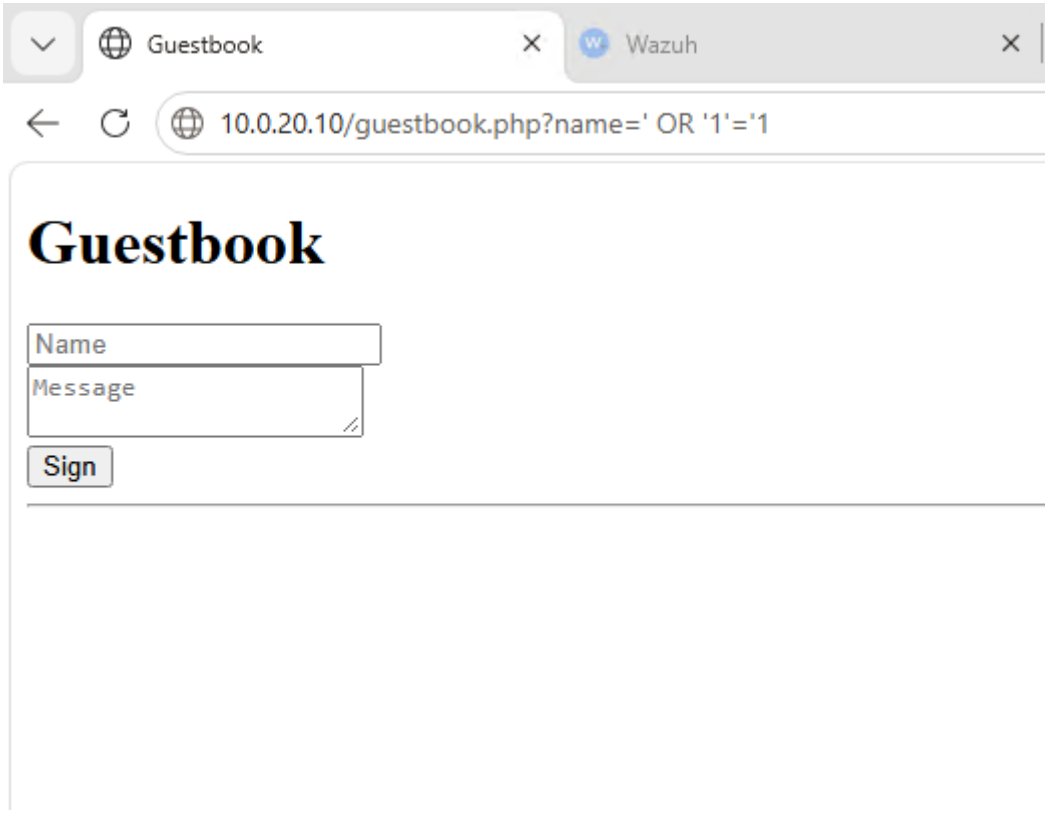


Filter bypass

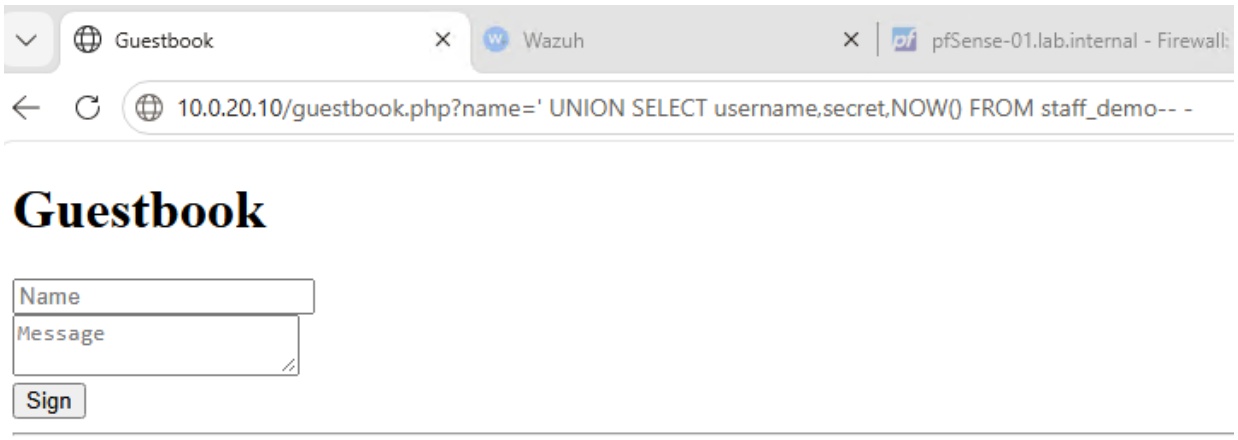


UNION leak

Secure page, same payloads



Bypass attempt on secure page



UNION attempt on secure page

Takeaways

- Prepared statements stop SQL injection: the same payloads that errored, bypassed the filter, and leaked data on the vulnerable page returned nothing on the secure one.
- A least-privilege DB account limits what a successful injection can do.
- `staff_demo` contained fake data only.

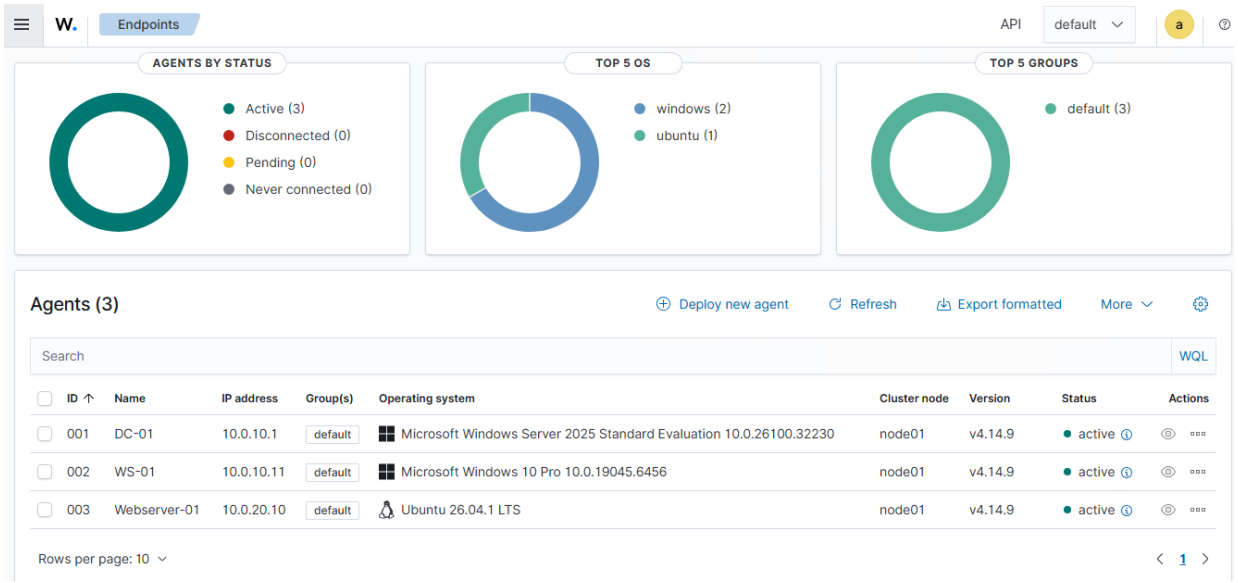
5. Monitoring and detection with Wazuh

Deployment

Wazuh 4.14.9 all-in-one (manager, indexer, dashboard) on an Ubuntu 26.04 LTS VM (Wazuh-01, hostname Wazuh-Server) at 10.0.10.3, 8 GB RAM `TODO(verify)`, fixed memory. Dashboard at `https://10.0.10.3`.

Agents

Agent	OS	Network path
001 DC-01	Windows Server 2025	LAN, direct
002 WS-01	Windows 10 Pro	LAN, direct
003 Webserver-01	Ubuntu 26.04 LTS	DMZ, allowed by pfSense rule on TCP 1514-1515



Endpoints summary

The Linux agent monitors the Apache access and error logs, auth logs, and the journal.

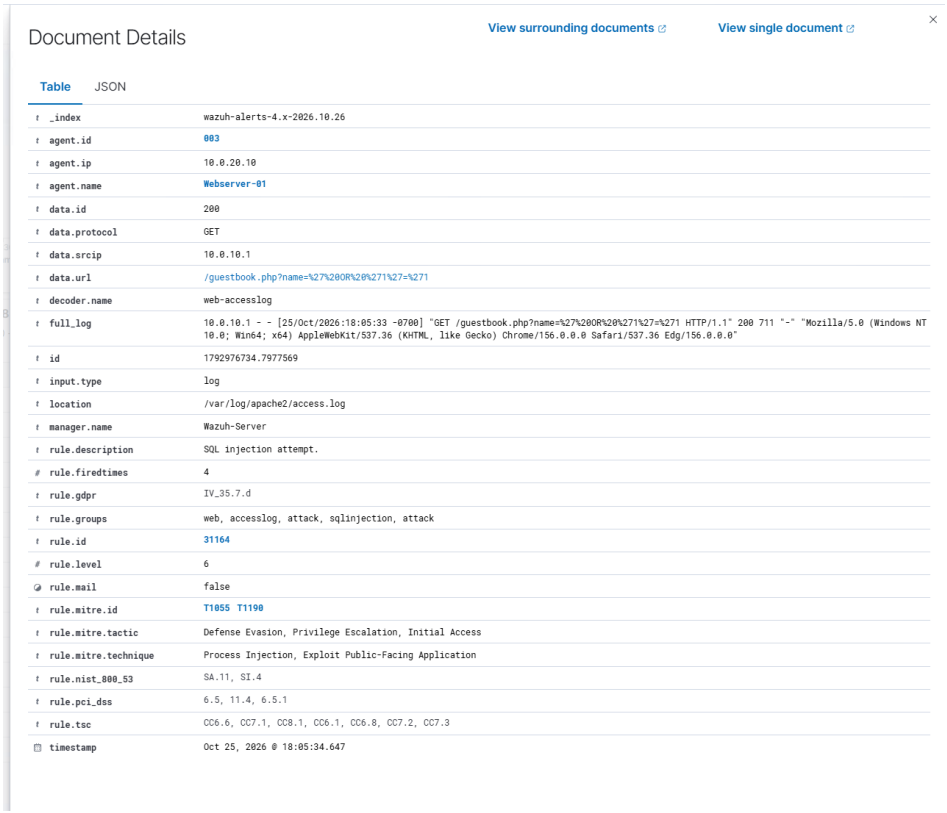
Detections observed

Rule ID	Description	Triggered by
31164	SQL injection attempt	`OR '1'='1'`, `UNION SELECT` URLs
31105	XSS (cross-site scripting) attempt	A `<script>` tag in a request URL (a probe, not a full XSS test)
31106	A web attack returned code 200	Attack patterns that got an HTTP 200
5402 / 5501 / 5502	sudo to root, PAM session open/close	Admin activity on the web server

timestamp	agent.name	rule.description	rule.level	rule.id
Oct 25, 2026 @ 18:06:54.6...	Webserver-01	A web attack returned code 200 (success).	6	31106
Oct 25, 2026 @ 18:05:34.6...	Webserver-01	SQL injection attempt.	6	31164
Oct 25, 2026 @ 18:05:08.6...	Webserver-01	SQL injection attempt.	6	31164
Oct 25, 2026 @ 18:04:50.6...	Webserver-01	SQL injection attempt.	6	31164
Oct 25, 2026 @ 18:02:26.6...	Webserver-01	SQL injection attempt.	6	31164
Oct 25, 2026 @ 17:58:48.6...	Webserver-01	XSS (Cross Site Scripting) attempt.	6	31105
Oct 25, 2026 @ 17:57:40.6...	Webserver-01	A web attack returned code 200 (success).	6	31106
Oct 25, 2026 @ 17:57:16.6...	Webserver-01	SQL injection attempt.	6	31164
Oct 25, 2026 @ 17:54:36.6...	Webserver-01	PAM: Login session closed.	3	5502
Oct 25, 2026 @ 17:53:22.6...	Webserver-01	Successful sudo to ROOT executed.	3	5402
Oct 25, 2026 @ 17:53:22.6...	Webserver-01	PAM: Login session opened.	3	5501
Oct 25, 2026 @ 17:52:44.6...	Webserver-01	PAM: Login session closed.	3	5502
Oct 25, 2026 @ 17:52:44.6...	Webserver-01	Successful sudo to ROOT executed.	3	5402
Oct 25, 2026 @ 17:52:44.6...	Webserver-01	PAM: Login session opened.	3	5501
Oct 25, 2026 @ 17:52:44.6...	Webserver-01	Successful sudo to ROOT executed.	3	5402

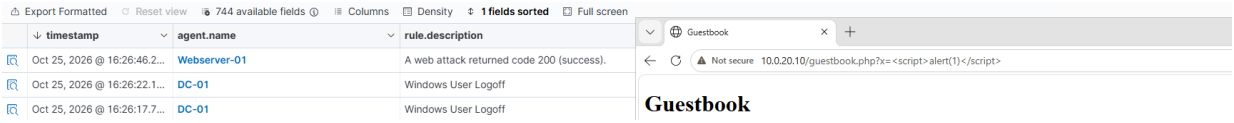
Web attack alerts

An expanded SQL injection alert (rule 31164) shows the source IP (10.0.10.1, DC-01), the requested URL, the raw Apache log line, and the MITRE ATT&CK mapping (T1190, Exploit Public-Facing Application):



Alert detail

The `<script>` URL probe as it appeared in Wazuh, next to the request that caused it:



XSS attempt

Query used: `agent.name: "Webserver-01" and rule.groups: web`

Limits of this detection

- Wazuh flagged the **pattern** in the request, not whether the attack worked. Rule 31106 fires on HTTP 200 for any attack-looking request; only the vulnerable page actually leaked data. The alert detail above is for a request to the secure page, which returned 200 and no data.
- The Apache access log records URLs but not POST bodies, so attacks submitted in form (POST) bodies are not visible. Catching it would need a WAF such as ModSecurity or application-level logging.

- Default rules only; no custom decoders or tuning.

6. Troubleshooting and lessons learned

Problem	Cause	Fix / lesson
LAN VM could not ping pfSense	Ping target typed as 10.0.1.254 instead of 10.0.10.254	Check the address before suspecting the network
DMZ web server unreachable	New pfSense interface had no rules; Ubuntu had no persistent gateway	Add DMZ rules; set static IP, gateway, and DNS with nmcli
Web pages "not loading"	Browser used HTTPS against a server only serving HTTP (Apache), and the reverse for Wazuh	Always include the scheme when testing by IP
PHP install failed	Typo in package name	Read the error; it names the package
PHP 500 error	Config file still held the placeholder DB password	Check `/var/log/apache2/error.log` first
`DROP TABLE` succeeded unexpectedly	Test was run as root, not the app user	Run `SELECT CURRENT_USER();` before testing privileges
Table creation failed	`TEST` typed instead of `TEXT`; mismatched quotes left MariaDB waiting for input	Paste SQL from a file or script
SSH "connection refused"	`openssh-server` not installed	Refused = nothing listening; timeout = firewall
SSH `Permission denied (publickey)`	Key never added; `-i` pointed at the `.pub` file; key not in default folder	Compare fingerprints with `ssh-keygen -lf`; use the private key
Locked out of SSH	Password login disabled before the key worked	Test key login in a second session first; the Hyper-V console is the safety net
Wazuh install failed repeatedly	Root partition only 19 GB, dashboard install ran out of disk; earlier attempt used the multi-node command and left a broken dpkg state	Check `df -h` first; grow the partition with `growpart` and `resize2fs`; force-remove broken package scripts
Wazuh agent would not enroll	Install command used the wrong manager IP and ufw blocked 1515	Verify the manager address in generated commands
Windows agent slow to appear	First check-in took several minutes	Verify with the agent log before changing anything
Apache failed to restart	The word `sudo` was pasted into the config file	`apachectl configtest` names the file and line
DMZ not isolated	Allow-any rule sat above the block rule	pfSense uses first match; verify order and test it

Habits this reinforced

- Test one layer at a time and stop at the first failure.
- Keep a second access path (console) when changing remote access.
- Take snapshots before risky changes.
- Capture before and after evidence while building, not afterward.

7. Limitations and future work

Limitations

- **No secondary domain controller.** A second DC (DC-02) was planned and never built because of host RAM limits (32 GB shared across the VMs and the host). A production domain would run at least two for availability. A second DC is redundancy, not backup: replication copies accidental deletions to both controllers.
- **No backup and restore testing.** System state backups and database restores were planned and not performed, so the recovery story in this lab is untested.
- **No Group Policy.** No GPOs or security baselines (for example browser or CIS settings) were applied to the domain; the AD setup covers OUs, a user, groups, DNS, and DHCP only.
- **HTTPS not enabled** on the web server (self-signed certificate and HSTS planned).
- **No WAF.** Attacks sent in POST bodies do not appear in Wazuh because the access log omits request bodies.
- **No XSS demonstration.** Only a URL-based XSS probe was run (and detected by Wazuh). A stored XSS comparison between the vulnerable and secure pages was not completed.
- **Default Wazuh rules** with no custom decoders or alert tuning.
- **Single-host virtual lab.** Networking is simulated in Hyper-V, not physical hardware, and the pfSense build was a development release.
- **Windows 10** reached end of support in October 2025; a current Windows 11 client would be more representative.

Future work

1. Complete the backup and restore tests (web server and DC-01 system state).
2. Add HTTPS, an HTTP-to-HTTPS redirect, and HSTS.
3. Deploy ModSecurity with the OWASP Core Rule Set and compare detection.
4. Add a second DC when resources allow.
5. Apply a CIS or Microsoft security baseline through Group Policy and track the Wazuh SCA score.
6. Add an attacker VM (Kali) and run SSH brute force against fail2ban and Wazuh.
7. Move to VLANs with a trunk into pfSense.

Appendix: configuration files

apache-zz-hardening.conf

```
# /etc/apache2/conf-available/zz-hardening.conf
ServerTokens Prod
ServerSignature Off
TraceEnable Off

<Directory /var/www/>
    Options -Indexes +FollowSymLinks
</Directory>

<IfModule mod_headers.c>
    Header unset X-Powered-By
    Header always set X-Content-Type-Options "nosniff"
    Header always set X-Frame-Options "SAMEORIGIN"
    Header always set Referrer-Policy "strict-origin-when-cross-origin"
    Header always set Permissions-Policy "geolocation=(), microphone=(), camera=()"
    Header always set Content-Security-Policy "default-src 'self'; frame-ancestors 'self'"
</IfModule>
```

fail2ban-jail.local

```
# /etc/fail2ban/jail.local
[sshd]
enabled = true
backend = systemd
maxretry = 4
findtime = 10m
bantime = 1h
```

guestbook-db-setup.sql

```
-- Run as the MariaDB admin. Replace the password placeholder.
CREATE DATABASE guestbook CHARACTER SET utf8mb4 COLLATE utf8mb4_unicode_ci;
CREATE USER 'guestbook_app'@'localhost' IDENTIFIED BY 'CHANGE_ME';
GRANT SELECT, INSERT, UPDATE, DELETE ON guestbook.* TO 'guestbook_app'@'localhost';
FLUSH PRIVILEGES;

USE guestbook;
CREATE TABLE entries (
  id INT AUTO_INCREMENT PRIMARY KEY,
  name VARCHAR(100) NOT NULL,
  message TEXT NOT NULL,
  created_at TIMESTAMP DEFAULT CURRENT_TIMESTAMP
);
```

sshd-01-hardening.conf

```
# /etc/ssh/sshd_config.d/01-hardening.conf
PermitRootLogin no
PasswordAuthentication no
PubkeyAuthentication yes
AllowUsers web
MaxAuthTries 3
LoginGraceTime 30
X11Forwarding no
ClientAliveInterval 300
ClientAliveCountMax 2
AllowTcpForwarding no
AllowAgentForwarding no
MaxSessions 2
TCPKeepAlive no
LogLevel VERBOSE
```

ufw-rules.txt

```
sudo ufw default deny incoming
sudo ufw default allow outgoing
sudo ufw allow from 10.0.10.0/24 to any port 22 proto tcp
sudo ufw allow 80/tcp
sudo ufw allow 443/tcp
sudo ufw enable
```